PAYGO FINANCIAL TECHNOLOGIES LTD.

GDPR DATA MAPPING & SOC 2 READINESS ASSESSMENT

Capstone Project Report Template

Pod Group/Student name(s): POD NOVA (STEVEN DAIRO)

Submission date: 27-10-2026

Instructions for Use : Complete this report using the PayGo case study and course materials. Support every finding with a fact expressly provided in the scenario.

1. Executive Summary

Purpose and scope. This report is an initial, scenario-based GDPR data mapping and gap assessment and SOC 2 readiness assessment for PayGo Financial Technologies Ltd., a Dublin-based digital payments company with 120 employees. It covers the seven processing activities in the case study, plus email communications, which appears only as a provider relationship. The payment platform and supporting infrastructure are assessed against the Security, Availability and Confidentiality categories. No documents or systems were inspected: every finding rests on a fact stated in the scenario.

GDPR findings. Of 16 areas assessed, 7 are Confirmed gaps, 7 are Evidence gaps and 2 are No gap established. The confirmed gaps are an incomplete record of processing activities; a privacy notice that omits recipient categories and some retention periods; retention periods without documented justification and a schedule that does not cover card or email data; deletion that has not been tested across systems and providers; data protection roles and

vendor risk assessments that are not consistently recorded; processing locations and transfer arrangements that are not recorded; and the security evidence limitations under Art. 32. Strengths are a documented retention schedule and the decision not to store full card numbers or card verification codes.

SOC 2 findings. Four of the seven control areas show a confirmed weakness (access management, incident response testing, change management evidence and third-party risk management) and three show unresolved evidence gaps (multi-factor authentication, alert review and backup restoration). Policies exist for access, incident response, change, backup and vendor management, but the scenario does not show that they operate effectively, and no central evidence register exists. Of 26 evidence items, 7 are available, 9 have an evidence gap identified, and 10 are not specified.

Evidence limitations. The scenario does not state lawful bases, processing purposes, provider roles and locations, the content of provider agreements, data subject request and breach procedures, or MFA coverage. These are reported as evidence gaps, not as failures. Missing evidence would still be treated as an exception by a SOC 2 auditor.

Priority recommendations. The 6 High-priority actions are: complete the vendor register with roles, locations, transfer mechanisms and risk assessments; map permissions to roles and complete access reviews for the support system and logging platform; document and close MFA gaps; run an incident response tabletop and confirm the breach notification process; and complete the record of processing activities. 12 Medium and 2 Low priority actions follow in Section 6, including the privacy notice, retention and deletion, change, backup and alert-review evidence, and a central evidence register.

2. Business and Assessment Scope

Business. PayGo Financial Technologies Ltd. is a fictional fintech company headquartered in Dublin, Ireland. It provides a digital payment platform for individuals and small businesses in Ireland and other EU countries and has 120 employees. Management wants to strengthen data privacy and information security practices and prepare for a potential SOC 2 examination.

Processing environment. The scenario describes seven processing activities: customer registration, identity verification, payment processing, customer support, employee administration, security monitoring and card payments. PayGo relies on cloud infrastructure and external providers for payment processing, identity verification, customer support, payroll and email communications. PayGo does not store full payment card numbers or card verification codes in its application database; the external payment processor handles the card details needed to complete card transactions.

GDPR assessment scope. PayGo is established in the EU, so GDPR applies (Art. 3(1)). On the facts given it appears to act as controller for these activities; provider roles are not stated in the scenario and are treated as an open finding. The assessment covers the ten requirement areas in the brief, with DPIA screening (Art. 35) added as an additional consideration.

Proposed SOC 2 scope. PayGo proposes to assess its payment platform and supporting infrastructure against Security, Availability and Confidentiality. This is a proposal and not an agreed examination scope. PayGo has not undergone a SOC 2 examination and has no central evidence register linking controls to criteria.

Systems and third parties. Systems named: PayGo web and mobile applications, payment platform and database, customer support ticketing system, Human Resources system, central logging platform, cloud hosting, external payment processor and identity verification provider. The vendor register and signed agreements cover six provider types: cloud hosting, payment processing, identity verification, customer support, payroll and email. Providers are not named.

Limitations. This is a desktop exercise based only on the scenario. Nothing was inspected or tested, and no interviews were held. Where the scenario is silent the matter is recorded as an evidence gap or as unspecified, not as a failure. Proposed owners and priorities are recommendations, not facts about PayGo's structure. This report is not legal advice.

3. GDPR Data Mapping Report

3.1 Data Inventory

Table 3.1 inventories the seven activities in the case study and adds email communications, which the scenario names only as a provider. "Apparent" purposes and inferred data subjects are the assessor's reading of the activity names; the scenario states neither. Anything not stated is recorded as unspecified. The same inventory appears in the workbook sheet "GDPR Data Inventory".

Processing activity	Data categories	Data subjects	Purpose	System /recipient	Retention	Information not specified
Customer registration	Full name, email address, phone number, residential address, date of birth	Customers (inferred from the activity; not stated)	Apparent: creating customer accounts (not stated)	PayGo web and mobile applications **External recipient:** None identified in the scenario	Customer account information: while the account is active and for five years after closure	Lawful basis; whether data comes from sources other than the customer; hosting location; whether marketing consent is collected; whether contact data is shared with other providers (for example the email provider).
Identity verification	Name, date of birth, address, identity document details, verification result	Customers and prospective customers (inferred; not stated)	Apparent: verifying customer identity (not stated)	Identity verification provider's service (the scenario names only the provider) **External recipient:** Identity verification provider	Identity verification records: five years after account closure	Provider's data protection role (processor or controller); processing location; retention at the provider; whether biometric or selfie data is used; lawful basis; legal source for the five-year period.
Payment processing	Transaction reference, amount, currency, date, status, payer and recipient account identifiers	Payers and payment recipients (indicated by the data categories)	Apparent: executing and recording payments (not stated)	PayGo payment platform and database **External recipient:** None identified in the scenario	Transaction records: seven years	Lawful basis; whether payment recipients are informed of the processing; database hosting location; legal source for the seven-year period; how this activity relates to card payments.

Processing activity	Data categories	Data subjects	Purpose	System /recipient	Retention	Information not specified
Customer support	Customer name, contact details, ticket description, screenshots or attachments submitted by customers	Customers (inferred); other individuals may appear in attachments (not stated)	Apparent: handling customer requests (not stated)	Customer support ticketing system **External recipient:** Not identified in the activity table; the vendor register lists a customer support provider but its link to this system is not stated	Customer support tickets: three years after ticket closure	Provider role and location; what attachments contain (for example identity or card data); whether data is minimised or redacted; whether the ticketing system is provider-hosted.
Employee administration	Employee name, contact details, job title, department, payroll details	Employees	Apparent: HR and payroll administration (not stated)	Human Resources system **External recipient:** Not identified in the activity table; the vendor register lists a payroll provider but its link to this activity is not stated	Employee records: six years after employment ends	Exact payroll fields (for example bank or tax identifiers); payroll provider role and location; lawful basis; legal source for the six-year period; treatment of job applicants (not stated).
Security monitoring	User account identifier, login time, IP address, authentication result, relevant system events	System users: staff, and possibly customers (not stated)	Apparent: detecting and investigating security events (not stated)	Central logging platform **External recipient:** None identified in the scenario	Security logs: twelve months	Whether the platform is provider-hosted; who can access the logs; whether users are told about monitoring; lawful basis; which systems feed the platform.

Processing activity	Data categories	Data subjects	Purpose	System /recipient	Retention	Information not specified
Card payments	Payment token, card brand, last four digits of the card number, transaction authorisation result	Customers (inferred; not stated)	Apparent: authorising card transactions (not stated)	External payment processor (it handles the card details needed to complete transactions) **External recipient:** External payment processor	Not stated. The schedule has no card-specific entry; the data may fall under transaction records (seven years), which the scenario does not confirm	Processor's role (processor or independent controller); processing location; retention at the processor; whether PayGo stores the token and result or only the processor does; retention of those items at PayGo.
Email communications (activity not described in the scenario)	Not described in the scenario	Not described	Not described	Not described **External recipient:** Email provider (vendor register only)	None stated	The entire activity: data categories, data subjects, purpose, lawful basis, provider role, location and retention. Missing record of processing entry.

3.2 Written Data Flow Descriptions

The flows below use only what the scenario states. Collection channels marked "inferred" follow from the system named. Where onward sharing, storage location or deletion is not described, the limitation is recorded instead of assuming a flow. No diagram is drawn, as instructed.

Processing activity	Data source	System / recipient	Storage / retention	Deletion practice / evidence gap
Customer registration	Customer, through the PayGo web and mobile applications (collection channel inferred from the system named; not expressly stated).	PayGo web and mobile applications. No external recipient identified. **Use:** Details are captured in the applications to set up the customer's account. Onward sharing is not described.	Kept while the account is active and for five years after closure. Storage location is not stated.	No deletion practice described. Deletion has not been tested across all systems and providers, and the justification for the five-year period is not documented.

Processing activity	Data source	System / recipient	Storage / retention	Deletion practice / evidence gap
Identity verification	Customer-supplied identity details (inferred; how they are collected is not stated).	Identity verification provider (external). **Use:** Name, date of birth, address and identity document details are verified by the provider, which returns a verification result. The direction and mechanism of the transfer are not described.	Records kept for five years after account closure. Whether they sit at PayGo, the provider or both is not stated.	Deletion untested across systems and providers. The provider's role, location, retention and deletion terms are not recorded. Justification for the period is not documented.
Payment processing	Payment transactions made on the PayGo platform, including payer and recipient account identifiers. How recipient details are obtained is not stated.	PayGo payment platform and database. **Use:** Transaction details are recorded in the PayGo database. Onward sharing is not described, apart from the card element handled by the external processor (see Card payments).	Transaction records kept for seven years. Database location is not stated.	Deletion untested. Justification for seven years is not documented. Whether payment recipients are informed of the processing is not evidenced.
Customer support	Customers, who submit tickets that may include screenshots or attachments.	Customer support ticketing system. The vendor register lists a customer support provider, but its link to this system is not stated. **Use:** Ticket details and attachments are held to handle customer requests. Sharing beyond the system is not described.	Kept for three years after ticket closure. Storage location is not stated.	Deletion untested at the provider. Attachment content is customer-controlled and may contain more data than needed, so minimisation is not evidenced. Justification for the period is not documented.
Employee administration	Employee data held by Human Resources (original source not stated).	Human Resources system. The vendor register lists a payroll provider, but its link to this activity is not stated. **Use:** Employee and payroll details are used for HR and payroll administration. The flow to a payroll provider is not described.	Employee records kept for six years after employment ends. Storage location is not stated.	Deletion untested across systems and the payroll provider. Justification for six years is not documented.

Processing activity	Data source	System / recipient	Storage / retention	Deletion practice / evidence gap
Security monitoring	Generated automatically from user logins and system events (inferred from the data categories).	Central logging platform. **Use:** Login and event records are collected for security monitoring. The scenario does not show that all critical alerts are reviewed within defined timeframes.	Security logs kept for twelve months.	Deletion not tested. Completed access reviews are missing for this platform (also a SOC 2 finding). Whether logs are deleted at twelve months is not evidenced.
Card payments	Cardholder card details submitted during a card payment (inferred; mechanism not stated).	External payment processor. **Use:** The processor handles the card details needed to complete the transaction. PayGo's data items are the token, card brand, last four digits and authorisation result. PayGo does not store full card numbers or card verification codes in its application database.	No retention period stated for PayGo's card data. Retention of full card details at the processor is not stated.	No retention or deletion rule for PayGo's card data. Deletion at the processor is untested, and the processor's role and location are not recorded.
Email communications (activity not described in the scenario)	Not described.	Email provider (vendor register only). **Use:** Not described.	None stated.	Cannot be assessed. Missing record of processing entry; no retention rule.

4. GDPR Gap Assessment

The ten requirements in the brief are assessed below, and the first column explains what each means for PayGo. Storage limitation, data minimisation and processor findings are split where the evidence supports different statuses. DPIA screening (Art. 35) is added as an additional consideration. Statuses follow the definitions in the brief.

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed
Lawfulness, fairness and transparency Arts. 5(1)(a), 12–14 **What it means:** Individuals (customers, payment recipients, employees) must be told clearly who handles their data, why, who receives it and for how long it is kept.	The privacy notice does not clearly identify every category of recipient or explain all applicable retention periods.	**Confirmed gap** The notice is incomplete on recipients and retention. Whether it covers payment recipients and employees is not stated.	Individuals are not properly informed, creating complaint and regulatory exposure and weakening trust in a financial service.	Update the notice to list recipient categories and retention periods for each activity once the RoPA is complete. Check coverage for payment recipients and employees.	Current privacy notice(s) and version history; completed RoPA; Art. 13/14 checklist; proof of publication.
Lawful basis for processing Art. 6 (Art. 9 if special category data arises) **What it means:** Each activity needs a documented lawful basis, such as contract or legal obligation. Special category data needs an additional condition.	No lawful basis is stated for any activity. The scenario does not say whether identity verification uses biometric data.	**Evidence gap** Cannot be verified from the scenario. It is not treated as a failure.	Processing may lack a documented basis, so PayGo cannot demonstrate accountability (Art. 5(2)). Biometric use, if any, would need further analysis.	Record a lawful basis for each activity in the RoPA, with legitimate interests assessments where relied on. Confirm with the DPO or counsel and confirm the identity verification method.	RoPA lawful basis field; legitimate interests assessments; description of the identity verification method; counsel or DPO sign-off.
Purpose limitation and data minimisation Art. 5(1)(b), (c) **What it means:** Data must be collected for specified purposes and limited to what is necessary for them.	No purposes are documented in the scenario. Customers can submit screenshots or attachments to customer support.	**Evidence gap** Cannot be verified. Free-form attachments may contain more data than needed.	Over-collection, for example screenshots showing identity or card details, increases breach impact and retention burden.	Document the purpose of each activity. Review a sample of support attachments and add upload guidance or redaction.	Purposes recorded in the RoPA; support ticket form and guidance; redacted sample of attachments; field necessity review.

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed
Data minimisation: card data Art. 5(1)(c), Art. 32 **What it means:** Card data held by PayGo should be limited to what is necessary and protected.	PayGo does not store full payment card numbers or card verification codes in its application database; the external processor handles card details.	**No gap established** The scenario facts do not establish a deficiency. This design choice supports minimisation. It does not verify backups, logs, attachments or the processor.	Residual risk only: card details could appear in support attachments or logs (not stated).	Keep the boundary documented. Confirm card data is absent from logs, backups and ticket attachments, and that the processor contract covers it.	Architecture or data flow document; database schema; processor agreement; log and attachment sampling.
Accuracy Art. 5(1)(d) (and Art. 16) **What it means:** Personal data must be accurate and corrected without delay.	The scenario describes no accuracy or correction process for customer or employee data.	**Evidence gap** Cannot be verified from the scenario.	Inaccurate details could cause failed payments, verification errors or payroll mistakes.	Document how customers and employees update their data and how corrections reach providers.	Account update and HR change procedures; sample correction record.
Storage limitation: justification and coverage Art. 5(1)(e) **What it means:** Data must be kept no longer than necessary, so each retention period needs a justification and every data category needs a rule.	A schedule exists, but PayGo has not documented the justification for every period. The schedule lists six categories and has no entry for card authorisation data or email communications.	**Confirmed gap** Justifications are missing, which is a confirmed gap. Coverage of card and email data is also open.	Data may be kept longer than necessary, or without a rationale PayGo can defend to a regulator.	Record the legal or business justification for each period (confirmed by counsel). Add the missing categories, with an owner and annual review.	Retention register with justifications and legal sources; approval record; updated schedule mapped to the RoPA.
Storage limitation: existence of a retention schedule Art. 5(1)(e) **What it means:** A documented schedule is the starting point for storage limitation.	PayGo has a documented retention schedule with six data categories and defined periods.	**No gap established** The existence of a schedule does not establish a deficiency. This does not verify the periods are appropriate or enforced (see adjacent rows).	None arising from the existence of the schedule itself.	Maintain the schedule and review it at least annually.	Approved schedule showing owner, version and review date.

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed
Storage limitation: deletion Arts. 5(1)(e), 17 **What it means:** Data must actually be deleted at the end of its retention period or on a valid erasure request, including at providers.	Deletion has not been tested across all systems and external providers.	**Confirmed gap** Deletion cannot be shown to work end to end.	Data may remain at providers or in backups after retention ends, and erasure requests may be incompletely fulfilled.	Document deletion steps for each system and provider, including backups. Run an end-to-end test with sample records and obtain provider confirmations.	Deletion procedure; test plan and results; provider deletion confirmations; backup expiry settings.
Records of processing activities Art. 30 **What it means:** PayGo must keep a complete record of its processing activities and produce it to the supervisory authority on request.	The records of processing activities are incomplete. Email communications has a provider in the vendor register but no described processing activity.	**Confirmed gap** The RoPA does not yet cover all processing.	PayGo cannot demonstrate accountability or give a complete record on request, and notices, retention, transfers and rights handling are weakened.	Complete the RoPA with the Art. 30(1) fields for every activity, add email communications, interview each department for other activities, and assign owners and a review cycle.	Approved RoPA covering all activities; department sign-offs; review schedule.
Data protection roles and processor relationships Arts. 4(7)-(8), 26, 28(1) **What it means:** PayGo must know whether each provider is a processor, controller or joint controller and use only providers giving sufficient guarantees.	A vendor register and signed agreements exist for six providers. Records do not consistently identify data protection roles. Documented risk assessments and ongoing monitoring are incomplete for some providers.	**Confirmed gap** Roles and due diligence are not consistently documented.	Unclear responsibility, and unvetted providers handling identity, payment, support and payroll data.	Classify each provider's role per activity (confirm the card processor and identity verification provider in particular), complete risk assessments and set a monitoring schedule.	Updated vendor register with roles; completed risk assessments with dates; monitoring records.

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed
Processor contract content Art. 28(3) **What it means:** Processor contracts must contain the mandatory terms (instructions, confidentiality, security, sub-processors, assistance, deletion or return, audit).	Signed agreements exist with the six provider types, but the scenario does not describe their terms.	**Evidence gap** Cannot be verified from the scenario.	Agreements may lack mandatory terms or sub-processor controls.	Review each agreement against an Art. 28(3) checklist and add data processing addenda where needed.	Agreements and addenda; completed checklist for each; sub-processor lists.
Security of personal data Art. 32 **What it means:** PayGo must apply appropriate technical and organisational measures and regularly test their effectiveness.	Policies exist for access, incident response, change and backup. Some permissions are not mapped to approved roles; access reviews are missing for the support system and logging platform; MFA coverage is not documented; alert review is not evidenced; incident response is untested in twelve months; backup restoration and change approval are not evidenced.	**Confirmed gap** Policies exist, but several measures cannot be shown to operate. Unmapped permissions, missing access reviews and the untested incident response plan are expressly stated; the others are unresolved.	Unauthorised access or an undetected incident affecting identity and financial data, and no way to show security measures are tested.	Remediate through the SOC 2 control actions in the Remediation Plan (access, MFA, monitoring, incident response, change, backup).	See the SOC 2 Evidence Register.
Data subject rights and request handling Arts. 12, 15-22 **What it means:** PayGo must be able to respond to access, rectification, erasure and similar requests, normally within one month.	The scenario describes no process, owner or timescale for handling requests. Deletion is untested and the RoPA is incomplete, which could make locating data harder.	**Evidence gap** Cannot be verified from the scenario.	Missed one-month deadlines and difficulty finding or deleting data across providers.	Document a request procedure (intake, identity check, search across systems and providers, response, log), train support and HR, and test with a sample request.	Procedure; request log; test record; provider cooperation clauses.

Requirement / Article	Scenario evidence	Finding / status	Potential risk	Recommended action	Further evidence needed
Personal data breach procedures Arts. 33–34 **What it means:** PayGo must assess breaches, notify the regulator within 72 hours where required, notify individuals in high-risk cases and keep a breach record.	An incident response policy exists but has not been tested in the past twelve months. The scenario does not describe breach assessment, notification steps or a breach register.	**Evidence gap** The content and operation of breach procedures cannot be verified. The untested incident response is addressed in the SOC 2 assessment.	Late or missed notification beyond 72 hours, and an incomplete breach record.	Confirm or create a breach assessment and notification workflow and a register, include provider-to-PayGo notification expectations, and test through a tabletop exercise.	Incident response policy; breach procedure and register; tabletop report; provider breach notification clauses.
International transfers Arts. 44–49 (Chapter V) **What it means:** Any transfer of personal data outside the EEA needs a valid mechanism, such as an adequacy decision or standard contractual clauses.	Provider records do not consistently identify processing locations or applicable international transfer arrangements.	**Confirmed gap** A documentation gap is confirmed. Whether any restricted transfer actually occurs is not stated.	A restricted transfer without a valid mechanism could go unnoticed, and PayGo cannot say where data is processed.	Record each provider's processing and sub-processor locations, identify any transfers outside the EEA, and document the mechanism and transfer risk assessment where needed.	Vendor register with locations and transfer arrangements; mechanism documents; transfer risk assessments.
Additional consideration: DPIA screening Art. 35 **What it means:** A data protection impact assessment is needed where processing is likely to result in high risk to individuals.	The scenario does not mention DPIA screening. Processing includes identity verification, financial transactions across several EU countries and security monitoring.	**Evidence gap** Cannot be verified from the scenario.	High-risk processing could proceed without a required assessment.	Screen the activities against the Art. 35 criteria (the DPIA checklist template can be adapted) and complete DPIAs where screening indicates need.	Screening records; completed DPIAs and approvals; DPO or counsel advice.

Assessment statuses: Confirmed gap; Evidence gap; No gap established.

"No gap established" does not independently verify full compliance.

5. SOC 2 Readiness Assessment

5.1 Trust Services Categories and Criteria

Criteria references follow the AICPA Trust Services Criteria (2017, with 2022 revised points of focus). The table explains why each criterion matters to PayGo's payment platform and supporting infrastructure.

Category / criterion	Why it is relevant	Scenario evidence	Finding or limitation
Security: CC6.1–CC6.3 (logical access)	Controls who can reach the payment platform, customer identity data, support tickets and logs.	Access management policy exists. Some permissions are not mapped to approved roles. Access reviews are missing for the support system and logging platform.	Confirmed weakness. Policy design exists; implementation and evidence are incomplete.
Security: CC6.1, CC6.6 (authentication and external threats)	The internet-facing platform and cloud administration rely on strong authentication to resist credential attacks.	MFA coverage across in-scope systems has not been documented.	Evidence gap.
Security: CC7.1–CC7.3 (detection and monitoring)	Monitoring logins and system events is the main way to detect misuse of a payment platform.	The central logging platform records user ID, login time, IP address, authentication result and events, kept twelve months. Records do not establish timely review of critical alerts.	Evidence gap on alert review. Vulnerability monitoring (CC7.1) is not described.
Security: CC7.3–CC7.5 (incident response and recovery)	Needed to contain and recover from incidents affecting payments and personal data.	An incident response policy exists but has not been tested in the past twelve months.	Confirmed weakness (untested).
Security: CC8.1 (change management)	Changes to a payment platform must be authorised, tested and approved to avoid outages and vulnerabilities.	A change management policy exists. Records do not consistently show approval and testing before deployment.	Confirmed weakness (inconsistent evidence).
Security: CC9.1, CC9.2 (risk mitigation and vendors)	The platform depends on cloud hosting, payment processing, identity verification, support, payroll and email providers.	A vendor register and signed agreements exist. Roles, locations, transfer arrangements and recent risk assessments are not consistently recorded, and assessments and monitoring are incomplete for some providers.	Confirmed weakness (CC9.2). Business disruption planning (CC9.1) is not described.

Category / criterion	Why it is relevant	Scenario evidence	Finding or limitation
Security: CC1–CC5 (control environment, risk assessment, monitoring and control activities)	An examiner tests governance, risk assessment and ongoing evaluation of controls alongside technical controls.	Policies exist for five areas. No central evidence register links controls to criteria. A formal risk assessment is not mentioned.	Confirmed gap: no evidence register (CC4.1). Evidence gap: risk assessment (CC3.1–CC3.4).
Availability: A1.1 (capacity and performance)	Customers rely on access to the platform in line with service commitments.	Service commitments and capacity or uptime monitoring are not described.	Evidence gap.
Availability: A1.2, A1.3 (backup, recovery and testing)	Backups and tested recovery protect against data loss and prolonged outage.	A backup and recovery policy exists. Restoration testing has not been evidenced.	Evidence gap.
Confidentiality: C1.1 (identifying confidential information)	The platform holds customer identity, contact and transaction data and employee payroll data that must be identified and protected.	PayGo does not store full card numbers or card verification codes in its application database. Data classification is not described.	Evidence gap. The card data boundary is a positive design fact.
Confidentiality: C1.2 (disposal of confidential information)	Confidential information must be disposed of when no longer needed, which links to retention and deletion.	A retention schedule exists. Deletion has not been tested across systems and providers.	Confirmed gap (deletion untested).
Processing Integrity and Privacy (not selected by PayGo)	Payment accuracy and personal data handling matter to customers, and the Privacy criteria overlap with the GDPR work.	Management proposed only Security, Availability and Confidentiality. The reason for excluding the others is not stated.	Not assessed. Management may confirm the category selection with the auditor.

5.2 Control Assessment

Each control area is assessed for policy design, implementation and evidence of operating effectiveness. "Confirmed weakness" means the scenario expressly states the deficiency and corresponds to "Confirmed gap". "Evidence gap" means the scenario is insufficient to conclude.

Control area	Policy / control described	Scenario evidence / limitation	Risk	Recommended action

Control area	Policy / control described	Scenario evidence / limitation	Risk	Recommended action
Access management and permissions Security: CC6.1, CC6.2, CC6.3 (logical access, user authorisation, role-based and least-privilege access). Applies because the payment platform, support system and logging platform hold customer identity, payment and log data.	An access management policy exists (design).	Some system permissions have not been mapped to approved job roles. Completed periodic access reviews are missing for the customer support system and central logging platform. The scenario does not say whether reviews exist for other systems or describe joiner and leaver handling. **Assessment:** Confirmed weakness: unmapped permissions and missing access reviews (implementation and operating-effectiveness evidence). Evidence gap: reviews for other in-scope systems and joiner/leaver practice.	Inappropriate access to support tickets (including customer attachments) and security logs; stale accounts go unnoticed; likely auditor exceptions under CC6.2 and CC6.3.	Build and approve a role-to-permission matrix and resolve exceptions. Perform and sign off access reviews for the support system and logging platform first, then all in-scope systems, at a defined frequency. **Evidence needed:** Approved role matrix; account listings; signed access reviews with dates; removal tickets; joiner and leaver samples.
Multi-factor authentication Security: CC6.1 (logical access security) and CC6.6 (protection against external threats). Applies because internet-facing platform and cloud administration depend on strong authentication.	No MFA requirement is described; whether the access management policy addresses MFA is not stated.	MFA coverage across all in-scope systems has not been documented. **Assessment:** Evidence gap: the scenario is insufficient to conclude whether MFA is in place.	If MFA is missing on administrative, support or cloud accounts, stolen credentials could expose payment and identity data. PayGo could not show the control to an auditor.	Inventory in-scope systems and account types, document MFA enforcement for each, enforce it for privileged and remote access first, and record approved exceptions. **Evidence needed:** System-by-system MFA configuration exports or screenshots; user coverage report; exception register.

Control area	Policy / control described	Scenario evidence / limitation	Risk	Recommended action
Security monitoring and alert review Security: CC7.2 (monitoring for anomalies) and CC7.3 (evaluating security events). Applies because monitoring is the main way to detect misuse of the payment platform.	The central logging platform records user account identifier, login time, IP address, authentication result and relevant system events, retained for twelve months. No alert-handling procedure is described.	Security monitoring records do not establish that all critical alerts are reviewed within defined timeframes. Access reviews are also missing for the logging platform (see access management). **Assessment:** Evidence gap: timely alert review cannot be shown. The scenario does not say whether reviews occurred without being recorded.	Delayed detection of unauthorised access or fraud, no proof of timely response, and late awareness of a personal data breach.	Define critical alert types and review timeframes, route alerts into tickets with assignee and timestamps, and report review metrics to management. Treat as a confirmed weakness if no records exist. **Evidence needed:** Alert definitions and timeframes; sample alert tickets with timestamps; monthly review metrics; monitoring procedure.
Incident response Security: CC7.3, CC7.4, CC7.5 (evaluating, responding to and recovering from incidents). Applies because an incident could affect payments and personal data.	An incident response policy exists (design).	Incident response procedures have not been tested during the past twelve months. The scenario does not describe past incidents or breach notification steps. **Assessment:** Confirmed weakness: the procedures are untested. Evidence gap: past incident handling and the content of the procedures.	Slow or uncoordinated response to an incident and a risk of missing the 72-hour breach notification deadline.	Run a tabletop exercise that includes a personal data breach, record lessons learned, update the plan, and keep an incident log. **Evidence needed:** Exercise report with attendees and actions; updated incident response plan; incident log and post-incident reviews.

Control area	Policy / control described	Scenario evidence / limitation	Risk	Recommended action
Change management Security: CC8.1 (authorising, designing, testing and approving changes). Applies because changes to a payment platform can cause outages or introduce vulnerabilities.	A change management policy exists (design).	Change records do not consistently demonstrate approval and testing before deployment. **Assessment:** Confirmed weakness in evidence: records are inconsistent. Unresolved: whether unapproved or untested changes were actually deployed.	Unauthorised or untested changes could disrupt the platform or create vulnerabilities, and sample testing by an auditor would likely produce exceptions.	Require ticket, approval and test evidence before deployment through workflow controls, define emergency change handling and review a sample each month. **Evidence needed:** Workflow configuration; sample change records with approval and test results; emergency change log; monthly sample review.
Backup and recovery Availability: A1.2 (backup and recovery infrastructure) and A1.3 (testing recovery procedures). Applies because customers rely on platform availability.	A backup and recovery policy exists (design).	Backup restoration testing has not been evidenced. Recovery objectives and backup schedules are not described. **Assessment:** Evidence gap: the scenario is insufficient to conclude that backups can be restored.	Backups may not be restorable, extending an outage or causing data loss on the payment platform and putting availability commitments at risk.	Define recovery objectives, perform and document a restore test for critical systems, and schedule recurring tests. **Evidence needed:** Recovery objectives; restore test report with results and sign-off; test schedule; backup job logs.
Third-party risk management Security: CC9.2 (vendor and business partner risk). Confidentiality: C1.1 where providers hold confidential data. Applies because the platform relies on six provider types.	A vendor management policy exists. A vendor register and signed agreements cover cloud hosting, payment processing, identity verification, customer support, payroll and email providers.	Provider records do not consistently identify data protection roles, processing locations, international transfer arrangements or recent security risk assessments. Documented risk assessments and ongoing monitoring are incomplete for some providers. **Assessment:** Confirmed weakness: incomplete risk assessment and monitoring. Evidence gap: contract terms and provider assurance reports.	Reliance on providers for hosting, payments and identity checks without assured oversight, and likely auditor exceptions. Subservice organisation responsibilities cannot be defined.	Run tiered risk assessments starting with cloud hosting, payment processing and identity verification, obtain provider assurance reports, set a monitoring schedule and complete the register. **Evidence needed:** Complete vendor register; dated risk assessments; provider SOC 2 or ISO reports; review minutes; agreements showing security terms.

5.3 SOC 2 Evidence Register

Status reflects the scenario only. "Available" means the scenario states the item exists; nothing was inspected, and its content and effectiveness are not verified. The register lists 26 items.

Control area	Evidence required	Status	Purpose	Further information needed
Access management and permissions	Access management policy (approved, versioned, with owner)	**Available**	Shows the control is designed and communicated (CC5, CC6.1).	The scenario states the policy exists. Approval date, version, owner and review history are not stated.
Access management and permissions	Role-to-permission matrix mapping approved job roles to system permissions	**Evidence gap identified**	Shows access is granted by role and on a least-privilege basis (CC6.3).	The scenario states some permissions are not mapped to approved roles. Which systems and accounts are affected is not stated.
Access management and permissions	Completed periodic access reviews for the customer support system and central logging platform, with sign-off and removal actions	**Evidence gap identified**	Shows access is reviewed and inappropriate access removed (CC6.2, CC6.3).	The scenario states completed reviews are missing. Whether reviews took place but were not recorded is not stated.
Access management and permissions	Completed access reviews for other in-scope systems (payment platform and database, cloud hosting, HR system)	**Not specified**	Shows review coverage across all in-scope systems.	The scenario is silent on these systems.
Access management and permissions	User provisioning and removal records for a sample of joiners, movers and leavers	**Not specified**	Shows access is authorised on joining and removed promptly on leaving (CC6.2).	The scenario does not describe joiner or leaver practice.
Multi-factor authentication	MFA enforcement settings and user coverage for each in-scope system, with documented exceptions	**Evidence gap identified**	Shows strong authentication protects the platform and supporting systems (CC6.1, CC6.6).	The scenario states MFA coverage has not been documented. Whether MFA is enabled is not stated.
Security monitoring and alert review	Central logging platform configuration: log sources, event types and twelve-month retention	**Available**	Shows security-relevant events are captured (CC7.2).	The scenario describes the platform and logged data. It does not confirm that all in-scope systems feed it.
Security monitoring and alert review	Alert rules, definition of critical alerts and required review timeframes	**Not specified**	Shows what must be reviewed and how quickly (CC7.2, CC7.3).	The scenario refers to defined timeframes but does not state them.

Control area	Evidence required	Status	Purpose	Further information needed
Security monitoring and alert review	Records of critical alert review (tickets or logs with timestamps and reviewer)	**Evidence gap identified**	Shows alerts are reviewed within defined timeframes (CC7.3).	The scenario states the records do not establish timely review.
Incident response	Incident response policy and procedures	**Available**	Shows incident handling is designed (CC7.3, CC7.4).	The scenario states the policy exists. Roles, escalation and breach notification content are not described.
Incident response	Record of an incident response test or tabletop exercise in the last twelve months, with lessons learned	**Evidence gap identified**	Shows the plan works in practice (CC7.4, CC7.5).	The scenario states procedures have not been tested in the past twelve months.
Incident response	Incident log and post-incident reviews	**Not specified**	Shows real incidents were detected, handled and closed.	The scenario does not say whether incidents have occurred.
Change management	Change management policy	**Available**	Shows change control is designed (CC8.1).	The scenario states the policy exists. Its content is not described.
Change management	Sample of change records with approval, testing and deployment evidence	**Evidence gap identified**	Shows changes are authorised and tested before release (CC8.1).	The scenario states records do not consistently demonstrate approval and testing. The share of changes affected is not stated.
Change management	Environment separation, emergency change and rollback records	**Not specified**	Shows controlled handling of urgent changes and failed releases (CC8.1).	The scenario is silent on these.
Backup and recovery	Backup and recovery policy	**Available**	Shows backup is designed (A1.2).	The scenario states the policy exists. Recovery objectives are not stated.
Backup and recovery	Backup schedules, job logs and defined recovery objectives	**Not specified**	Shows backups run as designed (A1.2).	The scenario does not describe schedules or objectives.
Backup and recovery	Backup restoration test results with sign-off	**Evidence gap identified**	Shows data and services can be recovered (A1.3).	The scenario states restoration testing has not been evidenced.
Third-party risk management	Vendor register	**Available**	Provides an inventory of providers (CC9.2).	The scenario states the register exists. Roles, locations and transfer arrangements are not consistently recorded.

Control area	Evidence required	Status	Purpose	Further information needed
Third-party risk management	Signed agreements with the six provider types	**Available**	Shows contractual security, confidentiality and data protection terms (CC9.2, C1.1).	The scenario states agreements are signed. Their terms (security, confidentiality, breach notice, sub-processors, deletion) are not described.
Third-party risk management	Recent security risk assessments and ongoing monitoring records for each provider	**Evidence gap identified**	Shows vendor risk is assessed and monitored (CC9.2).	The scenario states these are incomplete for some providers. Which providers is not stated.
Third-party risk management	Provider assurance reports (for example SOC 2 or ISO 27001) and review of complementary controls	**Not specified**	Supports reliance on providers and the treatment of subservice organisations.	The scenario does not describe assurance reports.
Governance and evidence management	Central evidence register linking controls to Trust Services Criteria	**Evidence gap identified**	Lets an auditor test controls and lets PayGo monitor them (CC4.1).	The scenario states no central evidence register has been established.
Risk assessment	Documented risk assessment and risk register	**Not specified**	Shows risks to the platform are identified and assessed (CC3.1–CC3.4).	The scenario does not mention a risk assessment.
Availability commitments	Documented service commitments with uptime and capacity monitoring	**Not specified**	Supports the Availability category (A1.1).	The scenario does not describe commitments or monitoring.
Confidentiality	Data classification or confidential information designation, and secure disposal records	**Not specified**	Supports the Confidentiality category (C1.1, C1.2).	The scenario does not describe classification or disposal records.

Evidence statuses: Available; Evidence gap identified; Not specified.

6. Integrated Gap Analysis and Remediation Plan

The findings of Parts A and B are consolidated into 20 actions, ordered by priority. Priority reflects the significance of the weakness, the sensitivity of the data, potential impact and the urgency of obtaining missing evidence. The GDPR and SOC 2 assessments were carried out separately, and actions that serve both are marked as shared remediation.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Provider records do not consistently identify data protection roles or recent security risk assessments. Documented risk assessments and monitoring are incomplete for some providers (cloud hosting, payment processing, identity verification, customer support, payroll, email).	GDPR Arts. 4(7)–(8), 28(1). SOC 2 CC9.2. Shared remediation.	Confirmed gap (GDPR and SOC 2)	Providers handle identity, payment, support and payroll data without assured oversight. Unclear accountability and likely SOC 2 exception.	Classify each provider's role per activity (confirm the card processor and identity verification provider), complete tiered risk assessments starting with identity verification, payment processing and cloud hosting, set a monitoring schedule and obtain assurance reports.	**High**	Vendor Management with Data Protection and Information Security	Updated vendor register with roles; dated risk assessments with approver; monitoring calendar and review records; assurance reports on file.
Provider records do not consistently identify processing locations or applicable international transfer arrangements.	GDPR Arts. 44–49 (Chapter V), Art. 30(1)(e). SOC 2 CC9.2.	Confirmed gap (GDPR, documentation)	A restricted transfer without a valid mechanism could go unnoticed. PayGo cannot say where customer data is processed.	Record each provider's processing and sub-processor locations, identify transfers outside the EEA, document the mechanism and transfer risk assessment where needed, and update the RoPA and privacy notice.	**High**	Data Protection with Vendor Management	Register with location and transfer columns complete; mechanism documents; transfer risk assessments; updated RoPA.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Some system permissions are not mapped to approved job roles. Completed periodic access reviews are missing for the customer support system and central logging platform.	GDPR Art. 32. SOC 2 CC6.1–CC6.3. Shared remediation.	Confirmed gap (GDPR and SOC 2)	Inappropriate access to support tickets (including attachments) and security logs. Stale accounts go unnoticed. Likely SOC 2 exceptions.	Build and approve a role-to-permission matrix, resolve exceptions, perform and sign off access reviews for the support system and logging platform first and then all in-scope systems, and set review frequency and owners.	**High**	Information Security with IT Operations	Approved role matrix; signed access reviews with dates; removal tickets; review calendar.
MFA coverage across all in-scope systems has not been documented.	GDPR Art. 32. SOC 2 CC6.1, CC6.6.	Evidence gap	If MFA is absent on administrative, support or cloud accounts, credential theft could expose payment and identity data. PayGo cannot show the control to an auditor.	Inventory in-scope systems and account types, document MFA enforcement for each system, enforce it on privileged and remote access first and record approved exceptions.	**High**	IT Operations with Information Security	System-by-system MFA configuration exports or screenshots; user coverage report; exception register.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Incident response procedures have not been tested in the past twelve months. Breach notification steps and a breach register are not described.	GDPR Arts. 33–34. SOC 2 CC7.3–CC7.5. Shared remediation.	Confirmed gap (SOC 2, untested). Evidence gap (GDPR, breach procedure)	Slow or uncoordinated response to an incident and a risk of missing the 72-hour notification deadline.	Run a tabletop exercise that includes a personal data breach, confirm or create a breach assessment, notification workflow and register, update the plan with lessons learned and set provider breach notification expectations.	**High**	Information Security with Data Protection	Exercise report with attendees and actions; updated incident response plan; breach procedure and register; provider breach clauses.
Records of processing activities are incomplete. Email communications has a provider in the vendor register but no described processing activity.	GDPR Art. 30.	Confirmed gap	PayGo cannot demonstrate accountability or give a complete record on request. Notices, retention, transfers and rights handling are weakened.	Complete the RoPA with the Art. 30(1) fields for every activity (add email communications), interview each department for undocumented activities and assign owners and an annual review.	**High**	Data Protection with department heads	Approved RoPA covering all activities; department sign-offs; review schedule.
Security monitoring records do not establish that all critical alerts are reviewed within defined timeframes.	SOC 2 CC7.2, CC7.3. GDPR Art. 32.	Evidence gap	Delayed detection of unauthorised access or fraud, no proof of timely response and late awareness of a breach.	Define critical alert types and review timeframes, route alerts into tickets with assignee and timestamps, and report review metrics monthly. Raise priority if no review records exist.	**Medium**	Information Security	Alert definitions and timeframes; sample alert tickets with timestamps; monthly metrics; monitoring procedure.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Change records do not consistently demonstrate approval and testing before deployment.	SOC 2 CC8.1. GDPR Art. 32.	Confirmed gap (SOC 2, evidence weakness)	Unauthorised or untested changes could disrupt the payment platform or create vulnerabilities. Likely SOC 2 sample exceptions.	Require ticket, approval and test evidence before deployment through workflow controls, define emergency change handling and review a sample each month.	**Medium**	IT Operations	Workflow configuration; sample of compliant change records; emergency change log; monthly sample review.
Backup restoration testing has not been evidenced.	SOC 2 A1.2, A1.3. GDPR Art. 32(1)(c).	Evidence gap	Backups may not be restorable, extending an outage or causing data loss on the payment platform and putting availability commitments at risk.	Define recovery objectives, perform and document a restore test for critical systems and schedule recurring tests.	**Medium**	IT Operations	Recovery objectives; restore test report with results and sign-off; test schedule; backup job logs.
The privacy notice does not clearly identify every category of recipient or explain all applicable retention periods.	GDPR Arts. 5(1)(a), 12–14.	Confirmed gap	Individuals are not properly informed. Complaint and regulatory exposure.	Update the notice with recipient categories and retention periods for each activity once the RoPA is complete. Check coverage for payment recipients and employees.	**Medium**	Data Protection with Compliance	Published revised notice(s) with change log; Art. 13/14 checklist; mapping from the RoPA.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
PayGo has not documented the justification for every retention period. The schedule has no entry for card authorisation data or email communications.	GDPR Art. 5(1)(e).	Confirmed gap	Data may be kept longer than necessary, or without a rationale PayGo can defend to a regulator.	Record the legal or business justification for each period (confirmed by counsel), add the missing categories and assign an owner and annual review.	**Medium**	Data Protection with Compliance	Retention register with justifications and legal sources; approval record; updated schedule.
Deletion has not been tested across all systems and external providers.	GDPR Arts. 5(1)(e), 17. SOC 2 C1.2. Shared remediation.	Confirmed gap (GDPR). Evidence gap (SOC 2, disposal records)	Data may remain at providers or in backups after retention ends. Erasure requests may be incompletely fulfilled.	Document deletion steps for each system and provider including backups, run an end-to-end test with sample records and obtain provider deletion confirmations.	**Medium**	IT Operations with Data Protection and Vendor Management	Deletion procedure; test plan and results; provider confirmations; backup expiry settings.
No lawful basis is stated for any activity. Whether identity verification uses biometric data is not stated.	GDPR Art. 6 (Art. 9 if applicable).	Evidence gap	Processing may lack a documented basis so accountability cannot be shown. Biometric use, if any, needs further analysis.	Record a lawful basis for each activity in the RoPA, complete legitimate interests assessments where relied on, confirm with the DPO or counsel and confirm the identity verification method.	**Medium**	Data Protection	RoPA lawful basis field; legitimate interests assessments; identity verification method description; sign-off.
The scenario describes no process, owner or timescale for handling data subject requests.	GDPR Arts. 12, 15-22.	Evidence gap	Missed one-month deadlines and difficulty locating or deleting data across providers.	Document a request procedure (intake, identity check, search across systems and providers, response, log), train support and HR, and test with a sample request.	**Medium**	Data Protection with Customer Support and Human Resources	Procedure; request log; test record; provider cooperation clauses.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Signed agreements exist with six provider types, but their data protection terms are not described.	GDPR Art. 28(3).	Evidence gap	Agreements may lack mandatory terms (instructions, security, sub-processors, assistance, deletion, audit).	Review each agreement against an Art. 28(3) checklist and add data processing addenda where needed.	**Medium**	Data Protection with Vendor Management	Completed checklist for each agreement; executed addenda; sub-processor lists.
Customers can submit screenshots or attachments to customer support, and processing purposes are not documented.	GDPR Art. 5(1)(b), (c).	Evidence gap	Attachments may contain unnecessary data such as identity or card details, raising breach impact and retention burden.	Document purposes for each activity, review a sample of attachments, add upload guidance or redaction and confirm card data is absent from tickets and logs.	**Medium**	Customer Support with Data Protection	Purposes in the RoPA; sample review notes; updated support guidance; redaction procedure.
No DPIA or screening is mentioned, although processing includes identity verification, financial transactions and security monitoring.	GDPR Art. 35.	Evidence gap	High-risk processing could proceed without a required assessment.	Screen activities against the Art. 35 criteria (the DPIA checklist template can be adapted) and complete DPIAs where screening indicates need.	**Medium**	Data Protection	Screening records; completed DPIAs and approvals; DPO or counsel advice.
No central evidence register links controls to criteria, and PayGo has not undergone a SOC 2 examination.	SOC 2 CC4.1, CC5. GDPR Art. 5(2) (accountability). Shared remediation.	Confirmed gap (SOC 2)	Controls cannot be tested efficiently and evidence gaps stay hidden, delaying a potential examination.	Build a control matrix and evidence register mapping each control to criteria, owner, frequency and evidence location. Start from this assessment's register, then select an auditor and agree scope.	**Medium**	Compliance	Control matrix and evidence register; owner assignments; auditor engagement or scoping record.

Finding / scenario evidence	GDPR / SOC 2 reference	Status	Risk	Corrective action	Priority	Proposed owner	Completion evidence
Service commitments, capacity monitoring, data classification and confidential information designation are not described, although Availability and Confidentiality are proposed for scope.	SOC 2 A1.1, C1.1.	Evidence gap	The criteria cannot be evidenced and the proposed scope may need revisiting.	Document service commitments and uptime and capacity monitoring, define confidential information and data classification, and confirm the category selection with the auditor.	**Low**	Compliance with IT Operations	Service commitments document; monitoring reports; classification policy and register; auditor scoping confirmation.
The scenario describes no accuracy or correction process for customer or employee data.	GDPR Art. 5(1)(d), Art. 16.	Evidence gap	Inaccurate data may cause failed payments, verification errors or payroll mistakes.	Document how customers and employees update data and how corrections reach providers.	**Low**	Data Protection with Human Resources and Customer Support	Update and correction procedures; sample correction record.

Priority: High / Medium / Low. Role assignments are proposed recommendations, not facts about PayGo's existing structure.

Shared remediation opportunities.

Third-party oversight. One vendor assessment programme (roles, locations, transfer mechanisms, risk assessments and contract review) closes the GDPR Art. 28 and Chapter V findings and the SOC 2 CC9.2 finding.

Access, authentication and monitoring. Role mapping, access reviews, MFA documentation and alert review evidence serve both GDPR Art. 32 and SOC 2 CC6 and CC7.

Incident and breach readiness. A single tabletop exercise that includes a personal data breach tests the SOC 2 incident response plan and the GDPR Arts. 33–34 notification workflow together.

Data mapping, retention and deletion. The completed record of processing activities feeds the privacy notice, retention register, transfer records and SOC 2 data classification (C1.1). Deletion testing serves GDPR Art. 17 and SOC 2 C1.2.

One evidence register. The SOC 2 evidence register can also hold GDPR accountability evidence (Art. 5(2)), so each artefact is collected once.

Framework-specific items. SOC 2 only: change management, backup restoration, alert review, availability commitments and the control matrix. GDPR only: privacy notice, lawful basis, data subject requests, accuracy, DPIA screening and processor contract terms.

7. Conclusion

This capstone project demonstrates how an evidence-based approach to GDPR and SOC 2 can strengthen an organisation's data privacy practices, information security controls, and compliance readiness. By applying data mapping, regulatory gap analysis, control assessment, and risk-based remediation, students gain practical insight into how GRC professionals help organisations like PayGo improve accountability, protect personal data, address control weaknesses, and prepare for an independent SOC 2 examination.